

Website Vulnerability Scanner Report

✓ <https://www.chiaraberti.cloud/>

Target added due to a redirect from <http://www.chiaraberti.cloud>

⚠ The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
[Upgrade to run Deep scans with 40+ tests](#) and detect more vulnerabilities.

Summary

Overall risk level:

Low

Risk ratings:

Critical: 0

High: 0

Medium: 0

Low: 6

Info: 3

Scan information:

Start time: Mar 29, 2026 / 15:10:24 UTC+02

Finish time: Mar 29, 2026 / 15:11:21 UTC+02

Scan duration: 57 sec

Tests performed: 38

Scan status: **Finished**

Findings

🚩 Missing security header: Referrer-Policy

port 443/tcp

CONFIRMED

URL	Evidence
https://www.chiaraberti.cloud/	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response.

▼ Details

Risk description:

The risk is that if a user visits a web page (e.g. "<http://example.com/pricing/>") and clicks on a link from that page going to e.g. "<https://www.google.com>", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Strict-Transport-Security

port 443/tcp

CONFIRMED

URL	Evidence
https://www.chiaraberti.cloud/	Response headers do not include the HTTP Strict-Transport-Security header

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

`Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]`

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://www.chiaraberti.cloud/	Response does not include the HTTP Content-Security-Policy security header or meta tag

▼ Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: X-Content-Type-Options

CONFIRMED

port 443/tcp

URL	Evidence
https://www.chiaraberti.cloud/	Response headers do not include the X-Content-Type-Options HTTP security header

▼ Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Robots.txt file found

port 443/tcp

CONFIRMED

URL

<https://www.chiaraberti.cloud/robots.txt>

▼ Details

Risk description:

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

<https://www.theregister.co.uk/2015/05/19/robotstxt/>

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

🚩 Server software and technology found

port 443/tcp

UNCONFIRMED ⓘ

Software / Version	Category
 Lozad.js	JavaScript libraries, Performance
 Clipboard.js	JavaScript libraries
 Contact Form 7 6.1.5	WordPress plugins, Form builders
 WP-Optimize	WordPress plugins, Performance
 jQuery Migrate 3.4.1	JavaScript libraries
 Google Font API	Font scripts
 GSAP 2.1.3	JavaScript frameworks
 HTTP/3	Miscellaneous
 jQuery	JavaScript libraries
 Modernizr	JavaScript libraries
 MySQL	Databases
 Nginx	Web servers, Reverse proxies
 OpenResty	Web servers
 PHP	Programming languages
 Smash Balloon Instagram Feed	WordPress plugins
 WordPress 6.9.4	CMS, Blogs
 Instagram Feed for WordPress	Widgets, WordPress plugins
 Aruba.it	Hosting, PaaS
 Lodash 1.13.7	JavaScript libraries
 RSS	Miscellaneous

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Security.txt file is missing

port 443/tcp

CONFIRMED**URL**

Missing: <https://www.chiaraberti.cloud/.well-known/security.txt>

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Email Address Exposure

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
https://www.chiaraberti.cloud/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: chiaraberti13@icloud.com
https://www.chiaraberti.cloud/navigating-the-ethical-hacking-universe	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: chiaraberti13@gmail.com

▼ Details

Risk description:

The risk is that exposed email addresses within the application could be accessed by unauthorized parties. This could lead to privacy violations, spam, phishing attacks, or other forms of misuse.

Recommendation:

Compartmentalize the application to have 'safe' areas where trust boundaries can be unambiguously drawn. Do not allow email addresses to go outside of the trust boundary, and always be careful when interfacing with a compartment outside of the safe area.

References:

https://owasp.org/Top10/A04_2021-Insecure_Design/

Classification:

CISA KEV: False

CVE : -1

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : A6: Security Misconfiguration

OWASP Top 10 - 2021 : A4: Insecure Design

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

API endpoints

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
https://www.chiaraberti.cloud/wp-json/wp/v2/pages	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Possible API endpoint found at /wp-json/wp/v2/pages Request / Response

▼ Details

Risk description:

These endpoints may represent an attack surface for malicious actors interested in API-specific vulnerabilities.

Recommendation:

Use the API Scanner to perform a more thorough vulnerability check for these endpoints, if an API specification is present.

Classification:

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Scan coverage information

List of tests performed (38)

Port 443

- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for client access policies
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion

- ✓ Scanned for internal error code
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for missing HTTP header - Rate Limit

Scan parameters

target: https://www.chiaraberti.cloud/
scan_type: Light
authentication: False

Scan stats

Unique Injection Points Detected:	112
URLs spidered:	14
Total number of HTTP requests:	24
Average time until a response was received:	788ms
